

7.15 audit unit 07b3 — embedded calls and assembled review

1. Identity and frozen scope

Owner: 7.15 firmware rehearsal. Worktree: /private/tmp/kk715-stack07b3-ready, branch release/715-stack-07b3-erc7730-embedded-ready, [firmware draft #867](#). Target: release/715-stack-07b2-erc7730-groups at 26ae09fe3. E code and companion predecessor: 6f9d56e4c (corrected EX screenshot audit). Python companion: deps/python-keepkey at fb94c5c (merged D review fix, runtime cases and screenshot audit), [companion draft #116](#). The main-worktree MASTER-AUDIT-TEMPLATE.md SHA256 is 743843a17139a7394325a961b9a38666c8e8af7a0005e0ff52eb94559ec8dbb7. This is the final code-bearing adjacent PR diff in the owner-authorized three-unit replacement for historical firmware PR #863.

E adds bounded inner-call binding and display to the A–C formatter and D group/iteration base. It accepts the supported embedded-call shape only when the definition and calldata agree. Unbound or unsupported inner calls are refused before review or shown as blind with an explicit warning. The signed outer and inner facts remain visible at device confirmation.

2. Git inventory and changed behavior

Immutable code and split-receipt inventory range: `git diff --numstat 26ae09fe3..52d0c8fad`. Current inventory range including this source report and PDF: `git diff --numstat 26ae09fe3..HEAD` on the final PR head. The inventory below is the adjacent E net diff. It includes tests, handoffs, the historical #863 report, split receipt and Python gitlink. The final report-containing PR head is recorded in the PR body.

Tracked path	Added	Deleted	Change and evidence
.github/workflows/ci.yml	1	1	Changed as part of this bounded audit unit.
deps/python-keepkey	1	1	Pins the matching compiler mirror and its tests.
docs/release/audit-units/715-07b-formatters-audit-20260925.md	339	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b-formatters-audit-20260925.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/release/audit-units/715-07b-reaudit-20260927-checks.json	895	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b-reaudit-20260927.md	134	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b-reaudit-20260927.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/release/audit-units/715-07b-split-receipt-20260926.md	140	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b-split-receipt-20260926.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/release/audit-units/715-07b3-embedded-audit-20260926.md	154	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b3-embedded-audit-20260926.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/security/HANDOFF-ERC7730-715-FORMATTERS.md	10	9	Records on-screen behavior and fail-closed limits.

Tracked path	Added	Deleted	Change and evidence
docs/security/HANDOFF-ERC7730-PHASE-E.md	209	0	Records on-screen behavior and fail-closed limits.
include/keepkey/firmware/erc7730_abi_stream.h	8	1	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_capabilities.h	17	7	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_catalog.h	9	5	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_field.h	9	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_workflow.h	49	1	Declares bounded state and the phase's runtime contract.
lib/firmware/erc7730_abi_stream.c	13	2	Captures only bounded ABI facts and records overflow.
lib/firmware/erc7730_capabilities.c	19	6	Selects the exact formatter and display capabilities.
lib/firmware/erc7730_catalog.c	29	8	Refuses unexecutable signed programs before review.
lib/firmware/erc7730_field.c	42	0	Formats decoded values with signer provenance visible.
lib/firmware/erc7730_workflow.c	243	7	Keeps replay, validation and UI state in sequence.
lib/firmware/fsm.c	2	1	Implements the phase's bounded decoding or display rule.
lib/firmware/fsm_msg_ethereum.h	268	26	Shows and confirms the device-decoded review screens.
scripts/emulator/test_stack07_regressions.py	6	484	Exercises signed wire requests and review screens.
unittests/firmware/erc7730_catalog.cpp	277	174	Covers accepted neighbors and fail-closed boundaries.
unittests/firmware/erc7730_field.cpp	24	0	Covers accepted neighbors and fail-closed boundaries.
unittests/firmware/erc7730_workflow.cpp	9	5	Covers accepted neighbors and fail-closed boundaries.

The earlier unit reports cover their own adjacent changes. The split receipt maps every path from #863 to A–C, D or E and records the historical finding clusters. E inherits D's later safety fixes, so the current source tree differs from historical #863 in those fixes.

3. Current-source findings and limits

Finding	Disposition and evidence
D2 embedded intent and D9 literal callee	Inner-call intent and callee are bound to decoded calldata before confirmation; mismatches fail closed.
D17 refused inner definition	Unsupported inner definitions are refused at preload. A malformed inner-call program cannot produce a trusted review screen.
Inner @.value without amountPath	An absent amount path cannot silently substitute a value; the catalog and workflow controls cover refusal.
Depth-two and call binding	The bounded parser and runtime reject unsupported nesting or mismatched calls; ABI, catalog, workflow and signed-wire cases cover neighboring valid and invalid shapes.
D15 pager continuation handling	The wire test filters continuation pages while retaining repeated content, so duplicate review screens remain observable.

Finding	Disposition and evidence
Historical Copilot status	#863 received three reviews with seven resolved findings. The split receipt assigns each finding to its owning unit. This E diff requires its own external review.
Mixed-array integration cases	The strict D formatter rule refuses a separate auxiliary array before review. E's embedded-call iteration test now uses one tuple array for both data and callee, retaining blind-screen coverage; the parallel-array case asserts preload refusal.
Screenshot audit after strict array binding	EX33 names the preload-refusal case with no declared screen; EX16 declares both dynamic and fixed-array element screens. The fixed-array case passed locally with five captured PNGs.

The historical 102-agent audit retained D1–D19 clusters but not all 42 raw finding rows. D13 and D19 are unnamed in the surviving handoff. The split receipt states that evidence gap; this report does not infer missing per-finding dispositions. Physical-device confirmation remains a separate release gate.

4. Verification and artifacts

Check	Exact source or run	Result and limit
Full native firmware	E integrated source, Docker run directory	firmware-unit 656/656 passed.
Host/device compiler mirror	Python fb94c5c, E firmware validator and emulator	Compiler/catalog: 24 pass, 3 local skips. Full official registry: 1,450 checked, 1,297 signable after the stricter array rule. Corrected runtime cases and fixed-array screens pass locally.
Corrected cppcheck	E integrated head 19d7a3025, Actions 36286655387	Hosted static analysis passed after D integration.
Historical hosted CI	#863 exact head 729ae7cfa, Actions 36263598278	All 16 required jobs passed; supporting code-equivalence evidence only.
Replacement hosted CI	#867 integrated predecessor, Actions 36285081374	Native/ARM/static and full runtime tests passed; the screenshot audit still declared one screen for the renamed parallel-array test, failing full and bitcoin-only integration and dependent report gates. Companion fb94c5c corrects EX33 and covers fixed-array EX16; final E head needs exact-head status.
Final integrated hosted evidence	E 19d7a3025, Actions 36286655387	All required jobs passed; full native 656, all 38 ERC-7730 runtime cases, full/bitcoin-only integration and report gates. No physical device used.

The canonical 7b pre-push script passed submodule cleanliness, unit-test registration and clang-format 20 in this worktree. It failed on inherited duplicate Osmosis/Solana nanopb options, the absent scripts/test_generate_test_report.py in the 7a base, and its own absent .cppcheck-build directory. The owner approved the 7b push with that exception recorded. The canonical gate is not called passing.

All three Copilot rounds on predecessor D found issues, now repaired. The owner chose to keep the existing drafts and stop before another split. D's code-review checkpoint stays open. E can be reviewed against the frozen D base; a clean E review would not close D or accept the assembled stack. No fourth D review is requested.

5. Report preflight and review checkpoint

The readable source and PDF carry the same inventory. The PDF is opened for legibility before push. The final live target and PR head are checked after the report commit. `git diff --check`, the code-review-diff gate, exact-head hosted CI and a new Copilot review belong to the final PR head. The historical #863 review is not a clean review of this adjacent E diff.

6. Review preparation and retrospective — 2026-09-27

The owner's follow-up requested preparation until ready for Copilot. The local re-audit source/PDF and evidence JSON accompany this report. They verify all three adjacent inventories, preserve 17 relocated wire tests (one renamed), retain D's

native test declarations, and inspect the final integrated CI's actual JUnit and report artifacts. E adds four native test declarations. Production source and the Python pin are unchanged after that validated head.

RA-01 is repaired in this candidate: the workflow now records companion BitHighlander/python-keepkey#116, replacing the stale upstream #197 link. The old generated artifact remains historical. CI on the final preparation head must regenerate the manifest before the new provenance is called verified. The earlier 25-path inventory is superseded by the expanded inventory above, which includes the workflow correction and re-audit artifacts.

The source audit covered inner chain/callee/selector binding, outer definition restoration, argument capture offsets, missing-value refusal, depth-two and iteration fallback, cancellation, and fixed-array UI expectations. No new firmware defect was confirmed. The historical raw-finding manifest gap and the limits of per-round audit records remain explicit, not waived by this pass.

Retrospective: the final screenshot failure came from changing a runtime test from review screens to preload refusal without changing EX33's declaration. EX16 also needed fixed-array screen declarations. Both were repaired and passed integrated CI. Inspecting the generated artifact then found RA-01, which a green report job had not detected. Before requesting review, bind the final manifest to the firmware head, Python pin and actual companion URL, and verify the report inventory against the live base/head. Readiness and eventual E review acceptance do not imply predecessor or release acceptance.